

*Standards & Guidance summarizes the supplied pages. The practical audit sections contain suggested applications, not additional IIA requirements. Risk ratings and findings are illustrative; red flags require further examination.*

---

## **Principle 5 — Maintain Confidentiality**

Internal auditors use information appropriately and protect its confidentiality, privacy, and ownership. This responsibility covers physical records, digital information, and information obtained through conversations and professional relationships.

Access granted for internal audit purposes carries a responsibility to prevent misuse and unauthorized disclosure.

### **Standard 5.1 — Use of Information**

**Domain:** II — Ethics and Professionalism

**Principle:** 5 — Maintain Confidentiality

#### **1. Standards & Guidance**

##### **Requirements**

- Internal auditors must comply with applicable policies, procedures, laws, and regulations when using information.
- Information must not be used for personal gain.
- Information must not be used in ways that conflict with or harm the organization's legitimate and ethical objectives.

##### **Considerations for Implementation**

Internal auditors' access to information enables them to perform their responsibilities without interference. Each auditor remains responsible for using and handling that information appropriately.

Policies and procedures should address the information lifecycle, including access, collection, transfer, storage, and destruction. Auditors should also understand and follow requirements applicable to third-party information.

The chief audit executive should communicate expectations for appropriate information use. Signed acknowledgments or other forms of confirmation may help demonstrate auditors' understanding.

Sensitive and personal information should receive appropriate digital protection, including measures such as passwords and encryption.

Examples of misuse include exploiting confidential financial, strategic, or operational information for personal investment decisions, selling information, or using proprietary knowledge to develop a competing product.

### Examples of Evidence of Conformance

- Evidence that controls over information access and use are designed and operating effectively.
- Documented information-use policies and procedures.
- Training materials and attendance records.
- Meeting minutes documenting discussions of appropriate information use.
- Auditor acknowledgments of relevant responsibilities and requirements.
- Performance reviews demonstrating compliance with applicable requirements.

### 2. Audit Focus Areas

- Use of information for legitimate professional purposes.
- Prevention of personal gain from confidential information.
- Compliance with information-use policies throughout the information lifecycle.
- Appropriate handling of third-party information.
- Auditor awareness of permitted and prohibited uses.
- Oversight of access, downloads, transfers, and subsequent use.

### 3. Risks

| <b>Risk</b>                                                                               | <b>Indicative Rating</b> |
|-------------------------------------------------------------------------------------------|--------------------------|
| Confidential information is exploited for personal or third-party benefit.                | High                     |
| Information obtained during an audit is used for an unauthorized purpose.                 | High                     |
| Third-party information is used contrary to applicable restrictions.                      | High                     |
| Sensitive data is transferred to unapproved tools or personal accounts.                   | High                     |
| Auditors misunderstand information-use responsibilities because expectations are unclear. | Medium                   |

#### 4. Controls

| Suggested Control                                                                       | Control Type           |
|-----------------------------------------------------------------------------------------|------------------------|
| Define acceptable information use and explicitly prohibit personal exploitation.        | Preventive             |
| Link data requests and access permissions to documented audit responsibilities.         | Preventive             |
| Communicate information-use expectations through training and acknowledgments.          | Preventive             |
| Define approved systems and methods for processing and transferring audit information.  | Preventive             |
| Monitor unusual access, downloads, and transfers, with documented review of exceptions. | Detective              |
| Establish procedures for reporting, investigating, and correcting suspected misuse.     | Detective / Corrective |

#### 5. Audit Procedures

| Procedure                                                                                     | Evidence to Examine                                               |
|-----------------------------------------------------------------------------------------------|-------------------------------------------------------------------|
| Review whether policies explain permitted uses and prohibit personal gain.                    | Information-use policies, code of conduct, audit methodology      |
| Sample information requests and assess their connection to legitimate audit responsibilities. | Data requests, engagement scopes, assignment records              |
| Examine selected downloads and transfers for compliance with approved practices.              | Access logs, transfer records, approvals                          |
| Review how restrictions on third-party information are identified and communicated.           | Agreements, handling instructions, staff communications           |
| Assess auditors' understanding of information-use responsibilities.                           | Training records, acknowledgments, interviews                     |
| Examine how suspected misuse was assessed and addressed.                                      | Incident records, investigation documentation, corrective actions |

#### 6. Red Flags

- Repeated access to records unrelated to assigned responsibilities.
- Unexplained bulk downloads of sensitive information.
- Transfers to personal email accounts or unapproved applications.
- Requests for commercially sensitive information without a clear audit purpose.
- Sharing confidential knowledge for personal business or investment activities.
- Attempts to avoid established monitoring or approval processes.

## 7. Common Findings — Illustrative Examples

- Information-use policies do not clearly prohibit personal exploitation.
- Access requests lack a documented professional purpose.
- Auditors use unapproved tools to process confidential information.
- Third-party information restrictions are not communicated to audit staff.
- Unusual downloads are recorded but not reviewed.
- Training does not explain practical examples of information misuse.

## 8. Professional References

- Global Internal Audit Standards — Standard 5.1: Use of Information.
- Principle 5: Maintain Confidentiality.
- Related standard: Standard 5.2 — Protection of Information.
- Applicable organizational information-use policies and third-party information agreements.

---

### Standard 5.2 — Protection of Information

**Domain:** II — Ethics and Professionalism

**Principle:** 5 — Maintain Confidentiality

#### 1. Standards & Guidance

##### Requirements

- Internal auditors must understand their information-protection responsibilities and respect the confidentiality, privacy, and ownership of information acquired through audit services or professional relationships.
- Internal auditors must understand and comply with applicable confidentiality, privacy, and information-security laws, regulations, policies, and procedures.
- Relevant responsibilities include custody, retention, and disposal of engagement records; release of records to internal and external parties; and handling information, copies, and access when no longer needed.
- Confidential information must not be disclosed to unauthorized parties unless a legal or professional responsibility requires disclosure.
- Internal auditors must manage the risk of accidental exposure or disclosure.
- The chief audit executive must ensure that the internal audit function and individuals assisting it follow the same information-protection requirements.

##### Considerations for Implementation

Protection arrangements should cover physical and digital information, including access, storage, retention, release, and disposal.

The chief audit executive should consult legal counsel to understand relevant legal requirements and protections, including legal privilege where applicable. Organizational procedures may require designated authorities to review and approve information before external release.

Protective measures may include:

- Encryption and password protection.
- Controlled email distribution.
- Restrictions on social media use.
- Physical access restrictions.
- Monitoring of information access.
- Revocation of digital permissions when access is no longer needed.
- Secure handling of printed records under established procedures.

The chief audit executive should periodically assess whether access remains necessary and whether access controls operate effectively. Confidential material may include individual salaries and personnel matters.

### **Examples of Evidence of Conformance**

- Records demonstrating implementation of information-protection methodologies.
- Evidence of controls restricting access and reducing opportunities to bypass safeguards.
- Information-protection training records.
- Auditor acknowledgments of applicable requirements.
- Restrictions on distribution of workpapers and final communications.
- Records of authorized disclosures and distribution.
- Documentation of legally required disclosures and relevant approvals, where applicable.
- Signed confidentiality or nondisclosure agreements.
- Performance reviews demonstrating appropriate protection and disclosure practices.

## **2. Audit Focus Areas**

- Protection of confidential audit information in physical and digital form.
- Access permissions and periodic access reviews.
- Secure distribution of workpapers and reports.
- Retention, custody, and disposal of engagement records.
- Prevention of accidental disclosure.
- Confidentiality obligations of external providers and other individuals assisting internal audit.
- Documented handling of authorized and required disclosures.

### 3. Risks

| <b>Risk</b>                                                                                        | <b>Indicative Rating</b> |
|----------------------------------------------------------------------------------------------------|--------------------------|
| Unauthorized users obtain confidential workpapers or reports.                                      | High                     |
| Sensitive information is accidentally disclosed through email, sharing links, or physical records. | High                     |
| Former staff or service providers retain unnecessary access.                                       | High                     |
| Audit records are destroyed prematurely or retained beyond applicable requirements.                | High                     |
| Individuals assisting internal audit apply inadequate information-protection practices.            | High                     |
| External disclosures occur without the required review or documented basis.                        | High                     |

### 4. Controls

| <b>Suggested Control</b>                                                                                   | <b>Control Type</b>     |
|------------------------------------------------------------------------------------------------------------|-------------------------|
| Apply role-based access permissions reflecting legitimate audit responsibilities.                          | Preventive              |
| Review permissions periodically and remove access when no longer required.                                 | Detective / Corrective  |
| Protect sensitive records through approved storage, encryption, authentication, and physical safeguards.   | Preventive              |
| Establish controlled distribution and approval procedures for workpapers and reports.                      | Preventive              |
| Apply documented retention and secure disposal procedures, including applicable preservation requirements. | Preventive / Corrective |
| Extend confidentiality requirements to contractors and others assisting internal audit.                    | Preventive              |
| Monitor potential disclosures and maintain an incident-response process.                                   | Detective / Corrective  |

## 5. Audit Procedures

| Procedure                                                                                             | Evidence to Examine                                                     |
|-------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------|
| Review whether protection procedures cover physical and digital information throughout its lifecycle. | Security policies, audit methodology, retention schedules               |
| Sample access permissions and assess whether they match current responsibilities.                     | User listings, assignments, access approvals, review records            |
| Test whether departed staff and completed service providers had unnecessary access removed.           | Departure records, contract completion dates, revocation logs           |
| Examine selected storage locations and transfer methods for appropriate safeguards.                   | System settings, encryption evidence, sharing configurations            |
| Sample report and workpaper disclosures for appropriate recipients and required approvals.            | Distribution lists, release records, documented disclosure basis        |
| Review retention and disposal practices against applicable requirements.                              | Archive inventories, disposal approvals, destruction records            |
| Assess whether individuals assisting internal audit follow equivalent protection requirements.        | Agreements, confidentiality commitments, training and oversight records |
| Examine accidental disclosure incidents and whether corrective actions addressed their causes.        | Incident reports, response records, follow-up evidence                  |

## 6. Red Flags

- Audit folders accessible through unrestricted sharing links.
- Shared accounts that prevent identification of individual users.
- Former employees or contractors retaining access.
- Confidential reports sent to unnecessarily broad distribution lists.
- Sensitive papers left in open areas or disposed of in ordinary waste.
- Unencrypted sensitive files stored on unapproved devices.
- External providers receiving records without established protection arrangements.
- Confidential audit matters discussed where unauthorized people can hear them.

## 7. Common Findings — Illustrative Examples

- Access permissions are not periodically reviewed.
- Unnecessary access remains active after assignment or employment changes.
- Workpaper distribution is not restricted to appropriate recipients.
- Retention schedules do not adequately address engagement records.
- Secure disposal is not documented or consistently performed.
- External assistance agreements omit relevant confidentiality obligations.
- Information releases lack required approvals or a documented disclosure basis.
- Accidental disclosure incidents are resolved without addressing recurring causes.

## 8. Professional References

- Global Internal Audit Standards — Standard 5.2: Protection of Information.
- Principle 5: Maintain Confidentiality.
- Related standard: Standard 5.1 — Use of Information.
- Applicable organizational confidentiality, information-security, records-retention, and disclosure policies.
- Relevant confidentiality agreements and applicable privacy requirements.

**Platform implementation note:** Maintain separate records for **5.1 — Use of Information** and **5.2 — Protection of Information**. Link shared controls to both where appropriate, while retaining the distinction between proper use and protection against unauthorized access or disclosure.